

Understanding Project Compass

Project Compass is an AI governance tool that helps organizations discover, assess, and manage AI tool risk. Detection and assessment run in the browser, and no organizational data leaves the device except for one narrow, documented exception described later on this page.

How Project Compass Works

Compass follows a four step process that takes raw network logs and produces a structured AI risk report aligned to the NIST AI Risk Management Framework.

Step 1: Upload Logs

Provide network or proxy logs, such as DNS, HTTP, or firewall exports, from your organization. Files are read locally in the browser. Nothing is uploaded to any server during this step.

Step 2: Detect AI Tools

The log parser matches hostnames against a registry of known AI service domains, including OpenAI, Anthropic, GitHub Copilot, and Hugging Face among others, and assigns each detected tool a risk tier based on its data exposure and external connectivity.

Step 3: Assess Controls

A 13 question governance questionnaire, along with four additional checks scored automatically from vendor registry data, maps an organization's practices against NIST AI RMF control domains. Responses generate a gap score across all four core functions: Govern, Map, Measure, and Manage.

Step 4: Generate Report

Three audience specific views, IT Security, Executive, and Auditor, summarize posture, gap score, and prioritized remediation recommendations.

How the NIST Framework Applies

Compass is built around the NIST AI Risk Management Framework (NIST AI 100-1, January 2023) and its generative AI companion, NIST AI 600-1 (July 2024), organized into four functions: **Govern** (policy, ownership, and training), **Map** (what AI tools exist and their risk), **Measure** (monitoring, review, and data protection), and **Manage** (incident response and enforcement). Compass evaluates 19 NIST controls across these four functions, through 13 analyst questions and 4 automated vendor checks.

How Scoring Works

Each control carries a severity weight: High = 100, Medium = 50, Low = 0 (tracked but not scored). Each answer earns a matching credit: Yes/Pass = 100 (met), Unsure/Partial = 50 (half a gap), No/Fail = 0 (unmet). A control's gap points equal its severity weight times (100 minus the answer score), divided by 100, summed across all controls and tools to produce the overall gap score.

Two Scores, Two Different Purposes

Compass scores two different things. Each AI tool gets a risk tier (Critical, High, Medium, Low) based on how dangerous the tool itself could be. Each NIST control gets a severity weight (High, Medium, Low) based on how serious it is if that particular safeguard is missing. The two scales look similar but measure different questions.

What the Log Parser Analyzes

The log parser is the detection engine at the core of Compass. It reads structured log files and matches hostnames and endpoints against a curated registry of known AI service domains, returning enriched tool metadata for each match.

Supported File Formats: .log, .txt, .csv, .json, exported from proxy servers, next generation firewalls, and DNS resolvers

Extracted Fields: Tool name, vendor, category, risk level, data classification, and access frequency

Risk Tier Assignment: Critical, High, Medium, or Low, based on data exposure potential, external connectivity, and model type

Tool Categories Detected: Generative AI and chat, code assistants, open source models, writing assistants, image generation, voice and speech, data pipelines, and search or retrieval tools

The AI Tool Inventory

After detection, every identified tool is added to an AI inventory, a structured registry a team can review, annotate, and act on. This provides a living record of AI usage across the organization and the foundation for a governance decision log.

Per Tool Metadata: Tool name, vendor, category, risk level, data classification, and relative access frequency derived from log volume

Approval Workflow: Each tool is individually marked Approved, Under Review, or Blocked, tracking governance decisions at the tool level

Analyst Notes: Any inventory row can be expanded to add free text notes documenting exceptions, risk acceptance rationale, or remediation steps

Session Storage: Inventory and notes persist within the active browser session. Persistent, cross session storage backed by a database is planned for a future release

Three Audience Tuned Report Views

The same assessment data, scored using the method described above, is presented three ways so each stakeholder receives the signal relevant to their role, without wading through sections written for a different audience.

IT Security View

Full tool list with risk tiers, per control gap analysis, OWASP LLM mapping, and technical remediation actions sorted by severity.

Executive View

One page posture summary with a gap score, maturity rating, and the top three priority recommendations, designed for a short leadership briefing.

Auditor View

NIST AI RMF control by control coverage table, evidence notes, and a compliance posture declaration formatted for audit documentation.

No Data Leaves the Browser, With One Documented Exception

Project Compass runs primarily as a client side application. Log files, questionnaire answers, and generated reports are processed within the browser tab and are not transmitted to any external server, with one narrow exception.

The optional "Explain This Finding" feature sends a small, non sensitive payload, limited to a NIST control identifier, its public description, and a gap status, to the Anthropic API through a local proxy, in order to generate a short plain language explanation. No organization name, log content, user identity, or inventory data is ever included in that request. Full detail on this feature, including a field by field data classification table, is available in the AI Governance Policy.

Log Files: Parsed in the browser using the File API. Raw file content is never uploaded to any server.

Session Data: Detection results, assessment answers, and inventory state are held in sessionStorage and cleared automatically when the tab is closed.

Profile: Organization name, user name, and role are saved to localStorage for returning user convenience, and cleared on sign out.

Authentication: Identity is verified through Microsoft Entra External ID using the PKCE flow. Tokens remain browser side; no Compass server holds user credentials.

Academic Context

Project Compass is a capstone project developed for the Master of Information and Cybersecurity (MICS) program, Summer 2026 cohort, at the UC Berkeley School of Information. It is intended as a demonstration of AI governance concepts and tooling, not a production security product. Use of sample or synthetic log data is recommended for demonstration purposes.